

인증 기본 교육

인증부터 상호인증까지

인증이 필요한 이유

인증(Authentication)이란?

인가(Authorization)이란?

IDP(Identity Provider)란?

SSO(Single Sign-On)란?

상호인증(Mutual Authentication)이란?

1. 인증이 필요한 이유



인증이 필요한 이유

인증(Authentication)이란?

인가(Authorization)이란?

IDP(Identity Provider)란?

SSO(Single Sign-On)란?

상호인증(Mutual Authentication)이란?

2. 인증(Authentication)이란?

- 인증 아주 간단하게 말해 "당신이 정말 당신이 맞는지 확인하는 과정"입니다.
- 우리가 특정 시스템이나 서비스에 접근하려고 할 때, 그 시스템이 "네가 누구인데?"라고 물어보고, 우리가 "나야, 나!"라고 증명하는 모든 절차를 의미합니다.
- 실제 대면 중의 인증에는 다음과 같은 방법들이 사용되어 왔습니다.
 - 암호
 - 증표
 - 인장
 - 수결
 - 안면 인식
 - 부절 (증표를 둘로 찢어서 나중에 합쳐보는 것)

2. 인증(Authentication)이란?

- IT 시스템은 우리가 '진짜 나'라는 것을 어떻게 확인할까요?
- 크게, 아래와 같은, 3가지 방법을 사용합니다.
최근에는 보안을 더욱 강화하기 위해 이 3가지 요소 중 2개 이상을 조합해서 사용하는 **다중 인증(Multi-Factor Authentication, MFA)**이 필수가 되고 있습니다.
- 예를 들어, 아이디/비밀번호로 로그인(아는 것)한 뒤,
스마트폰으로 날아온 인증번호(가진 것)를 추가로 입력하는 방식이 바로 다중 인증입니다.

종류 (인증 요소)	설명	예시	예시 2
아는 것 (Knowledge-based)	나만 알고 있는 정보	아이디/비밀번호, PIN 번호, 보안 질문	암구호
가진 것 (Possession-based)	나만 가지고 있는 물건	스마트폰 OTP 앱, 보안카드, 공인인증서(USB)	증표, 부절, 인장
나 자신 (Inherence-based)	나의 고유한 신체 정보	지문, 얼굴, 홍채, 목소리	안면 인식, 수결(필체, 행동 기반)

2. 인증(Authentication)



2. 만약 인증이 없다면?



인증이 필요한 이유

인증(Authentication)이란?

인가(Authorization)이란?

IDP(Identity Provider)란?

SSO(Single Sign-On)란?

상호인증(Mutual Authentication)이란?

3. 인가(Authorization)란?

- 인가란, 간단히 말해 **"당신의 권한을 확인하는 과정"**입니다.
- 우리가 특정 시스템이나 서비스에 접근할 수 있더라도, 거기서 모든 행동을 할 수 있는것은 아닙니다.
권한의 정도에 따라 접근할 수 있는 범위나 행동의 제약이 존재할 수 있습니다.

만약 무제한의 권한이 있다면 쇼핑몰에 들어가서 마음에 드는 물건의 가격을 바꿀 수도 있고, 마음에 들지 않는 물건을 임의로 삭제하는 등의 행동이 가능해 집니다.

3. 인가(Authorization)란?



3. 만약 인가가 없다면?



인증이 필요한 이유

인증(Authentication)이란?

인가(Authorization)이란?

IDP(Identity Provider)란?

SSO(Single Sign-On)란?

상호인증(Mutual Authentication)이란?

4. IDP (Identity Provider, 신원 제공자) 란

- IDP는 여러 웹사이트나 앱에서 사용할 수 있는 통합 '디지털 신분증'을 발급하고 관리해주는 신뢰할 수 있는 기관, 또는, 시스템을 의미합니다.
- IDP는 일반 회사 내에서 운영 및 관리될 수도 있으며, 인터넷에서는, **소셜 로그인**(예, 카카오톡 시작하기, **Sign in with Google**, 등) 형태로 존재할 수 있습니다.
- 이 과정은 다음과 같이 작동합니다.
 1. 나 (이용자): 쇼핑몰에 '네이버 아이디로 로그인' 버튼을 누른다.
 2. 쇼핑몰 (서비스 제공자): "네이버님, 이 사용자가 정말 네이버 회원이 맞나요?" 라고 물어본다.
 3. 네이버 (**IDP**): 나에게 네이버 아이디/비밀번호 입력이나 생체 인증을 요구하여 내가 '진짜 나'임을 확인한다.
 4. 네이버 (**IDP**): 확인이 완료되면, 쇼핑몰에게 "네, 이 사용자는 저희가 보증하는 진짜 회원입니다. 이름은 **OOO**이고, 이메일은 **XXX**입니다." 라고 인증서를 보내준다.
 5. 쇼핑몰 (서비스 제공자): 네이버가 보내준 인증서를 믿고 나를 로그인시켜 준다.

4. IDP에 의한 신원 보증



4. 만약 IDP가 없다면?



인증이 필요한 이유

인증(Authentication)이란?

인가(Authorization)이란?

IDP(Identity Provider)란?

SSO(Single Sign-On)란?

상호인증(Mutual Authentication)이란?

5. SSO (Single Sign-On) 란

- 매일 아침 회사에 출근해서 그룹웨어에 로그인하고, 또 메일 시스템에 로그인하고, 메신저에도 따로 로그인해야 한다면 정말 번거롭겠죠? **SSO**는 이 모든 과정을 단 한 번의 로그인으로 해결해주는 기술입니다.
- **SSO**는 **IDP**와 아래와 같은 형태로 연동해서 동작합니다.
 1. 최초 로그인 :
사용자가 그룹웨어와 같은 첫 번째 서비스에 접속하기 위해 **IDP**에 아이디와 비밀번호를 입력해 로그인합니다. (예: 회사 통합 계정으로 로그인)
 2. 인증 티켓(토큰) 발급 :
IDP는 사용자의 신원이 확인되면, 보이지 않는 '**인증 티켓(토큰)**'을 사용자의 웹 브라우저나, 첫 번째 서비스 프로그램에 발급해줍니다.
 3. 다른 서비스 접속 (자동 / 수동)
사용자가 이제 이메일 시스템이나 다른 회사 서비스에 접속하려고 하거나, 두 번째 서비스 프로그램이 자동으로 실행되어, **IDP**로부터 인증 결과를 기다리고 있습니다.
 4. 티켓(토큰) 확인 :
이메일 시스템, 또는, 두 번째 실행된 서비스 프로그램은 사용자에게 직접 로그인을 요구하는 대신, **IDP**가 발급한 인증 티켓을 요청하고, **IDP**는 2번에서 발급받은 인증 티켓을 전달합니다.
 5. 자동 로그인 :
이메일 시스템, 두 번째 실행된 서비스 프로그램은 **IDP**가 발급한 유효한 티켓임을 확인하고, 별도의 아이디/비밀번호 입력 없이 사용자를 즉시 로그인시켜 줍니다.

5. SSO (Single Sign-On) 로그인



5. SSO (Single Sign-On) 로그인



5. 만약 SSO가 없다면?



인증이 필요한 이유

인증(Authentication)이란?

인가(Authorization)이란?

IDP(Identity Provider)란?

SSO(Single Sign-On)란?

상호인증 (Mutual Authentication)이란?

6. 상호 인증 (Mutual Authentication) 이란

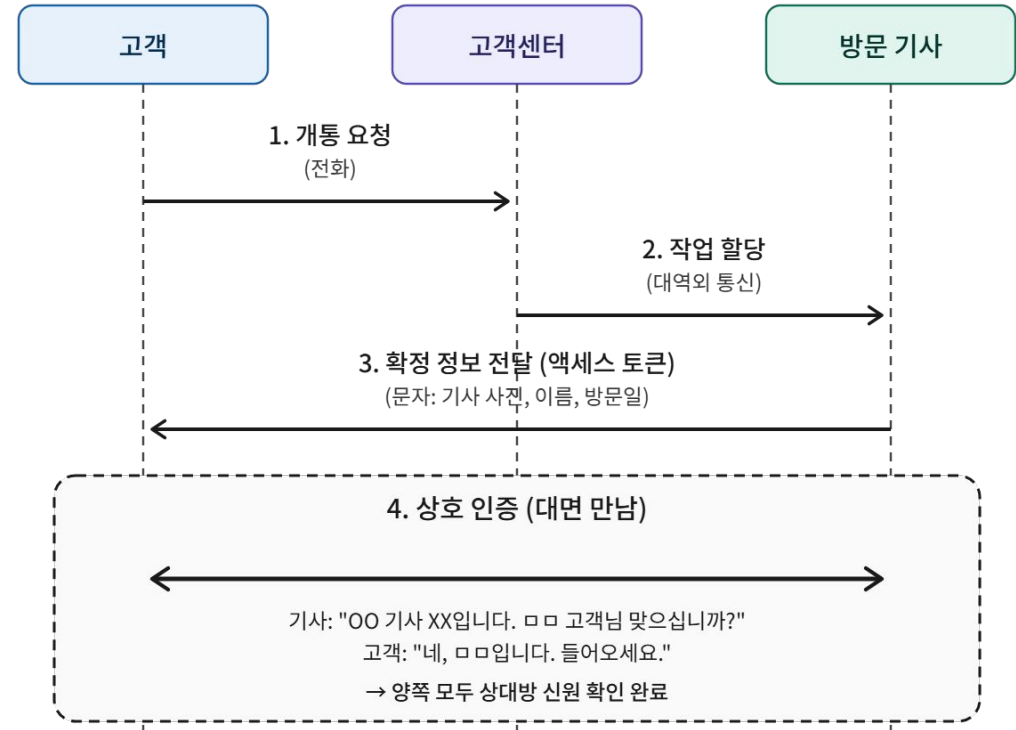
- 현존하는 대부분의 인증은 '**단방향 인증**'입니다. 즉, 서비스가 사용자(나)를 확인하는 과정만 존재합니다. ("너 우리 회원 맞아?"라고 서비스가 물어보면, 내가 아이디와 비밀번호를 대답하는 식입니다.)
- 하지만 상호 인증은, 사용자인 나도 서비스를 확인하는 방식입니다. ("너 내가 접속하려는 그 진짜 사이트 맞아? 혹시 가짜 피싱 사이트 아니야?"라고 되물어보는 과정이 추가된 방식입니다.)
- 단방향 인증만으로는 사용자가 가짜 웹사이트(피싱 사이트)에 속아 중요 정보를 탈취당하는 것을 막기 어렵습니다. (공격자가 실제 은행 사이트와 똑같이 생긴 가짜 사이트를 만들어 놓고 우리를 유인할 수 있습니다.)
- 이 사이트에, 아이디, 비밀번호, 보안카드 번호까지 모두 입력하면, 이 정보는 공격자에게 넘어가서, 공격자는, 이 정보로 실제 사이트에 로그인할 수 있게 됩니다.
- 상호 인증은 바로 이런 '파밍'이나 '피싱' 공격을 원천적으로 차단하기 위해 등장했습니다. 내가 접속하려는 사이트가 정말 신뢰할 수 있는 안전한 사이트인지, 스마트폰에서 먼저 확인하고 안전할 때만 정보를 교환할 수 있습니다.

6. 상호 인증의 실생활 예시

1. 서비스 요청
고객이 센터에 전화, "인터넷 개통할게요"
2. 대역외 통신
센터는 기사에게 작업량 할당
3. 액세스 토큰 요청
기사는 문자로 사진, 이름, 방문일 등 확정정보를 전달.
4. 상호 인증
기사 입장에서는 고객 이름, 집주소 확인.
고객 입장에서는 업체 이름, 기사 확인.

ex)

만나서 안녕하세요 OO 기사 XX입니다.
□□ 고객님의 맞으십니까?
네 □□입니다. 들어오세요.



6. 상호 인증



6. 만약 상호 인증이 없다면?



그래서 **Dualauth**가 하는 것

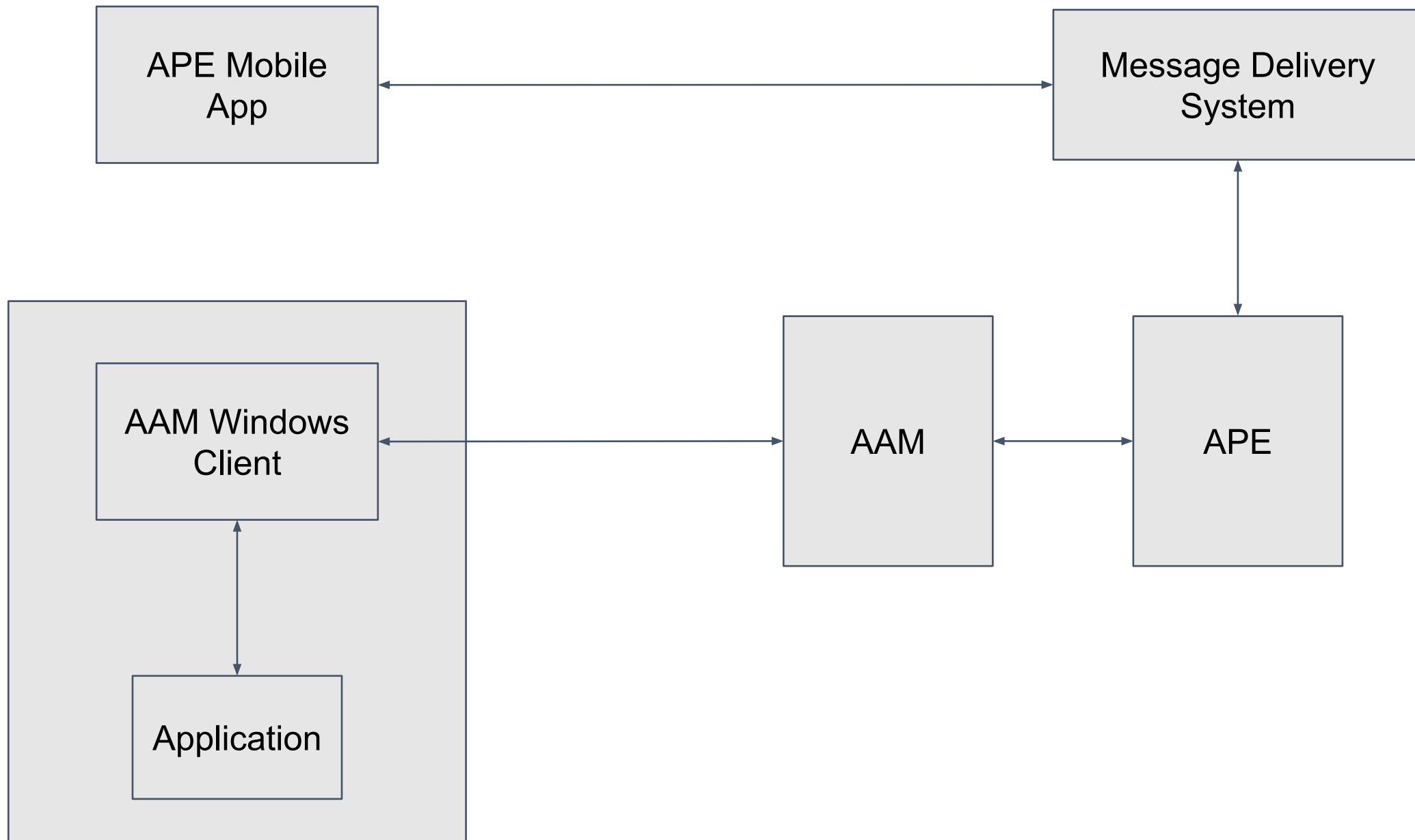
AutoPassword를 통한 온라인 상호 인증

#1. AutoPassword를 통한 온라인 상호 인증

- **AutoPassword는 스마트폰을 이용한 패스워드리스 기술로**, 사용자가 온라인 서비스에 패스워드를 입력하는 게 아니라 온라인 서비스가 사용자에게 자동 패스워드를 제시하고 사용자는 온라인 서비스가 제시한 자동 패스워드를 스마트폰 앱으로 대조해본 다음, 일치하는 경우 스마트폰의 생체인증으로 온라인 서비스의 자동 패스워드를 승인하는 패스워드리스 기술입니다.
- AutoPassword는 사용자의 패스워드 입증 책임을 온라인 서비스가 맡도록 하여 사용자를 패스워드로부터 해방시킨 패스워드리스 솔루션입니다.
- 사용자는 온라인 서비스가 제시하는 자동 패스워드를 확인하는 과정에서 **연결된 온라인 서비스가 진짜인지 가짜인지 확인할 수 있으며**, 온라인 서비스 역시 사용자가 자동 패스워드를 승인할 때 사용하는 **스마트폰의 생체인증을 이용하여 사용자를 인증**합니다.
- FIDO를 포함한 **기존 생체인증 기술**은 사용자 기기와 온라인 서비스간에 연결된 통신채널로 사용자 인증값을 전달하는 **대역내 생체인증 기술**입니다. 따라서 대역내 생체인증 기술은 사용자 **단말기(PC, 태블릿, 스마트TV 등) 마다 센서가 장착되어** 있어야 하기 때문에 기기별 생체인증 센서 배포에 따른 **비용 증가**와 함께 배포된 생체 인증 **센서 마다 사용자 생체 등록 절차**가 수반됩니다. 만약 대역내 생체 인증기술을 임의로 대역외로 사용하면 사용자는 자신의 생체인증 정보가 누구에게 제출되는 것인지 **확인하지 못한채** 인증정보를 제출하는 **보안 취약점**이 발생하게 됩니다.
- AutoPassword는 스마트폰의 생체인증 기술로 **센서가 부착되지 않은 장치(PC, 서버, 스마트TV, ATM, 키오스크 등)에서도 대역외로 안전하게 사용**될 수 있게 합니다.

#2. AAM(AutoPassword Access Manager)은 어떤 시스템인가?

- 사용자가 패스워드를 입력할 필요가 없이 **PC**나 서버가 사용자에게 자동 패스워드를 제시하고 사용자는 스마트폰에서 생성한 자동 패스워드와 이를 비교하여 생체인증으로 승인하면 **PC**나 서버에 접근하는 패스워드리스 기반 접근제어 솔루션입니다.
- AutoPassword Access Manager는 **국제표준기술로 제정된 ITU-T X.1280** 자동 패스워드가 적용된 기업용 접근제어 솔루션입니다.
- 관리자가 사용자에게 권한을 부여하면 사내 **PC**, 서버, 클라우드서비스 등에 **패스워드 없이** 접근할 수 있게 됩니다.
- 게다가 **PC**나 서버에 로그인 할 때 마다 자동으로 윈도우즈 및 리눅스 운영체제의 패스워드가 변경되어 사용자는 패스워드 관리를 해방됩니다.
- 생체인증기가 없는 일반 **PC**나 클라우드 서버에서 스마트폰 생체인증 기술을 대역외로 적용할 수 있는 국제표준 기술(X.1280)



Autopassword Access Manager(AAM)와 Autopassword Enterprise (APE) 실습

1. VM 생성 및 환경 설정
2. AAM, APE, DMZ 서버 통합 설치
3. 서버 라이선스 키 발급 및 업로드, 라이선스 키 검증 모듈 실행
4. APE 기본 설정
5. AAM 기본 설정 (Console / 관리자 웹)
6. Autopassword Enterprise 앱 설치
7. Autopassword Access Manager Windows Client 설치 및 로그인
8. Autopassword Access Manager Windows Client 삭제

Contact

DUALAUTH Co.,
Ltd.
www.dualauth.com
[sales@dualauth.co](mailto:sales@dualauth.com)
[m](mailto:sales@dualauth.com)